COLORADO
Information Security
Governor's Office of Information Technology

TS-CISO-012: Physical Security for IT Spaces

Document ID	TS-CISO-012
Title	Physical Security for IT Spaces
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	OIT, state agencies as defined in C.R.S. 24-37.5-101(28), and vendors contracted by OIT or its stakeholders, as a means to enforce technology standardization and assist in making the usage, support, and/or purchase of technologies more consistent and efficient.
Instrument Type	Standard
Version	2.0
Effective Date	05/01/2025
Last Updated	04/28/2026

Purpose

This standard is issued under the authority of the Governor's Office of Information Technology (OIT) (C.R.S. 24-37.5, et seq.) and the Office of Enterprise Architecture (Rule 8 CCR 1501-7). It provides specific requirements for managing data center security in spaces containing information technology (IT) systems.

Scope

These standards apply to OIT, state agencies as defined in C.R.S. 24-37.5-101(28), and vendors contracted by OIT or its stakeholders, as a means to enforce technology standardization and assist in making the usage, support, and/or purchase of technologies more consistent and efficient.

Standards instituted for use with the approval of the OIT Architecture Review Board (ARB) govern purchase and deployment decisions deemed "go-forward" or "net-new", and are not intended as a retroactively enforceable mandate for immediate conformance, especially where cost implications may be prohibitive.

Roles and Responsibilities

Enterprise Architecture - Chief Enterprise Architect

- Chairs and conducts business of the Architecture Review Board (ARB).
- Updates the effective date and/or last review date.
- Publishes the ARB-approved standard to the OIT public-facing website.

Architecture Review Board (ARB)

- Engages stakeholders and subject matter experts to determine standards.
- Reviews/approves the Standard (this document).

Information Security Office (CISO)

- Engages stakeholders and subject matter experts to inform the Standard.
- Updates document standards and version number.
- Presents to the Architecture Review Board for approval and adoption.

Enterprise Data Center Management Team

- Develops a process to ensure only authorized personnel are allowed access to the enterprise data center.
- Establishes and maintains an Access Authorization List (AAL); primary authority for adding or removing personnel from it.
- Maintains and audits all access processes to ensure they remain accurate and timely, and conducts periodic audits of the AAL.
- Reviews procedural changes to access management and is responsible for procedural compliance.
- Primary point of contact for audits and inspections related to the enterprise data center; accountable to the State Authority for effective data center security management.

Agency Management Team

- Develops an accurate Access Authorization List (AAL) of all authorized individuals; establishes and maintains a process for requesting and approving access.
- Primary authority for adding or removing personnel from the AAL; conducts periodic audits.
- Reviews procedural changes to access management and ensures procedural compliance.
- Primary point of contact for audits and inspections related to an agency data center and/or network closet physical security controls; accountable to the State Authority for effective physical security management; holds any physical keys to the data center/network closets.

Individual Contributor

- Submits a request to the Agency Management Team for access approval and addition to the agency ACL.
- Follows the applicable access procedure and security rules for the location they are entering.
- Notifies the Agency Management Team of any changes to their access, and of any actual or perceived security violations, as soon as possible.
- Escorts Data Center Visitors and ensures each visitor follows the security rules for their location.

Facility Visitor

- Follows the applicable access procedure and security rules for the location they are entering.
- Completely and legibly completes an entry in the visitor access log.

Standards

These standards define the specific measures necessary to maintain an appropriate security level for facilities housing critical information technology (IT) and support IT assets.

Intermediate Distribution Frame (IDF) / Data Closet Management

An Intermediate Distribution Frame (IDF), also called a "data closet," contains support IT assets and network switches, providing individual network connections to workstations, printers, and wireless access points within a building section or floor.

Within agency-owned buildings or leased spaces where the agency controls access, agency management should:

- Develop, approve, and maintain a process to ensure only authorized individuals have access to each IDF that provides support to the agency. Lock and key is the minimum acceptable security measure; agencies may use the ASACK Key Management process (for DPA-managed buildings); agencies in leased (non-DPA) spaces must track each individual issued a key; if a higher level of access control is used, a list of who is granted access must be maintained; verify individual access authorization before granting access; and secure spare keys, combinations, badges, and other physical access devices against unauthorized access.
- Develop an Access Authorization List (AAL) containing all personnel granted access to agency IDF spaces.
- Conduct an annual review of the AAL to verify that each individual continues to need access to the space.
- Vendors should not be included on the AAL or issued a physical key to any IDF the agency manages.
- Inventory every physical access device (keys, fobs, visitor passes, etc.) at least annually.
- Change combinations annually (if applicable), when compromised, or when individuals possessing them are transferred or terminated.
- Ensure that issued keys are returned as part of the off-boarding process.
- Change keys and/or other physical access devices when they are lost.

Main Distribution Frame (MDF) / Server Room Management

A Main Distribution Frame (MDF) is a central network hub for entire buildings or campuses where communication lines converge, containing critical IT assets such as switches, routers, and firewalls; where MDFs also contain servers and storage, these spaces are referred to as "Server Rooms."

Within agency-owned buildings or leased spaces where the agency controls access, agency management should:

- Develop, approve, and maintain a process to ensure only authorized individuals can access each MDF supporting the agency, using a programmable physical access control system that records entry activity, sufficient to identify individuals and when they entered.

- Agencies may use the ASACK access control system (for DPA-managed buildings); agencies in leased (non-DPA) spaces must use a system controlled and managed by agency personnel.
- Verify individual access authorization before granting access or issuing an access device; ensure ID badges are properly issued and revoked when no longer needed.
- Ensure physical keys that allow entry to the MDF are controlled and limited to Agency Management as much as possible.
- Maintain a visitor access log at the entrance to each MDF, capturing: location of the space; printed first and last name of the person entering; signature; purpose for entry; name of the escort; date; and time in/time out. The visitor's escort ensures each visitor signs in and all elements are legibly entered.
- Conduct monthly reviews of the visitor access log and the access control system logs.
- Develop an Access Authorization List (AAL) containing all personnel granted access to agency MDF spaces (may be combined with the IDF AAL, with access levels clearly defined).
- Conduct a quarterly review of the MDF AAL to verify continued need for access.
- Inventory every physical access device at least annually; change combinations annually when compromised or when individuals are transferred/terminated; ensure issued keys are returned at off-boarding; change devices when lost.
- Provide policy and training to ensure tailgating into an MDF is not authorized.
- Ensure MDFs containing sensitive data or information systems are secured to the standard required for those sensitive data types (e.g., FTI, PII, PHI, SSA, CJIS — see TS-CISO-001 Data Security for more detail).

Enterprise Data Center Management

An Enterprise Data Center is a State-owned facility operated by OIT, designed to host critical IT assets from multiple State agencies and meet requirements for physical security, power distribution, and environmental controls, managed by staff trained and certified in critical facilities infrastructure management.

Pertaining to critical facilities identified as an enterprise data center, Enterprise Data Center Management should:

- Develop, approve, and maintain a process to ensure only authorized individuals can access the enterprise data center, employing multiple layers of physical security so no single unauthorized attempt succeeds.
- Use a programmable access control system that grants access only to authorized personnel and removes it when no longer needed, and records main-entrance activity sufficient to identify individuals and entry times.
- Employ Two-Factor Authentication (2FA) to access spaces housing critical information systems; only Enterprise Data Center Management staff may manage the physical access control system.
- Verify individual access authorization before granting access or issuing an ID badge; ensure credentials are properly issued and revoked when no longer needed; minimize use of physical keys where an access control system is installed.
- Maintain a visitor access log at the entrance to each enterprise data center; all personnel except OIT employees assigned to the space must sign in, capturing: location; printed name; signature; organization; form of ID used; purpose for entry; name/organization of the person visited; date; and time in/out.
- Authorized visitors (State agency employees and verified contractors) do not require a full-time escort; the limit for any one escort covering several visitors is three (3).

- Conduct monthly reviews of the visitor access log and access control system logs; conduct a quarterly AAL review if utilized.
- Inventory every physical access device at least monthly; change combinations annually when compromised or when individuals are transferred/terminated; ensure issued keys are returned at off-boarding; change devices when lost.
- Ensure the entire data center is secured to the standards required for each sensitive data type present (e.g., FTI, PII, PHI, SSA, CJIS — see TS-CISO-001 Data Security for more detail).

Exceptions and Variance

Requests for variances from any provisions with this Standard must be requested using the Policy Exception Request (PER); instructions for submitting a PER can be found in the ServiceHub knowledge base. The PER process addresses business or technical reasons for the inability to adhere to one or more requirements in this standard; requests should include compensating controls, and will be processed and recommended for approval, conditional approval, or denial.

Compliance

Authorized visitors and escorted personnel are required to follow the specific security requirements for the IT space they are in. Failure to comply with security requirements or directions from agency management may result in the revocation of access privileges.

References

- CISP-011: IT Environmental Protection and Physical Security Policy, 12/19/2024
- CISP-004: Data Security Policy, 3/9/2026 (replaces CISP-011 on 07/01/2026)
- SOG-100-01: OIT Physical Access Standard Operating Guideline for IT Infrastructure, 3/3/2025

Definitions

- Agency or Agencies: Public agencies as defined in C.R.S. 24-37.5-102(26).
- Agency Managed Facility: A facility whose primary occupant and manager is any agency or organization other than OIT.
- CISO: Chief Information Security Officer, as defined in C.R.S. 24-37.5-403 unless otherwise referenced.
- Compensating Control(s): Security safeguards implemented in lieu of the required safeguard(s) that provide equivalent or comparable protection.
- Consolidated Agencies: State agencies whose IT functions were consolidated under OIT pursuant to SB 08-155 and defined in C.R.S. 24-37.5-102(28).
- Distribution Frame: The physical network infrastructure within a building or campus; end-user PCs connect to an IDF, and multiple IDFs connect to the MDF.
- Enterprise Data Center: A State-owned facility operated by OIT, designed to host Critical IT Assets from multiple State agencies and meet physical security, power distribution, and environmental control requirements.
- Exception: A deviation from any established security safeguard from this or any Colorado Information Security Policy (CISP).

- Intermediate Distribution Frame (IDF): Also called a “data closet”; contains support IT assets such as network switches and provides workstation, printer, and wireless access point connections by building section or floor.
- Critical IT Asset: Servers, storage, firewalls, and primary ingress/egress routers providing core access to Information Systems; loss or compromise will likely have major operational impact.
- Support IT Asset: Output devices and associated wired/wireless networking that provide individuals authenticated access to information systems; loss or compromise will likely impact one or a small group of users.
- Main Distribution Frame (MDF) / Server Room: A central network hub where communication lines converge, containing critical IT assets such as switches, routers, and firewalls (and, where applicable, servers and storage).
- Sensitive Data or Information: Information whose loss, misuse, unauthorized access to, or modification could adversely affect agency operations or individual privacy — including but not limited to FTI, PII, PHI, SSA, and CJIS data.
- User: All State of Colorado employees, temporary workers, contractors, interns, volunteers, third-party vendors, and others granted access to non-public state IT resources.